

Principales reglamentaciones vinculadas al Gobierno TI

Normas relacionadas con el Gobierno TI

Ley Sarbanes & Oxley - SOX (USA)

Ley de 2002, es conocida como Acta de reforma de la contabilidad pública de Empresa y de protección al accionista.

Su objetivo es monitorear el comportamiento de las empresas que cotizan en la bolsa de valores de Nueva York con el fin de evitar fraudes y riesgos financieros tales como bancarrotas o quiebras. Como así también, recuperar la confianza pública en el mercado, mejorar el gobierno corporativo, aumentar la responsabilidad de los ejecutivos y aumentar esfuerzos para prevenir, detectar, investigar y reparar los daños y malas conductas.

La Ley contiene 11 títulos y cada uno se aboca a una temática en particular:

- En su sección 302 establece la responsabilidad de la gestión (CEO y del CFO) por los reportes financieros. Los directivos son responsables por establecer y mantener el control interno. Deben presentar por escrito sus conclusiones sobre la efectividad de dichos controles a la fecha de emisión del informe.
- En la sección 404 adicionalmente a la mencionada establece la responsabilidad de la gerencia para el establecimiento y mantenimiento de una adecuada estructura de control interno y accesoriamente de la efectividad de esa estructura relacionada con la emisión de la información financiera (plataforma de *testing*).
- Premisas que introduce:
 - Una lista de incompatibilidades del auditor. No puede:
 - Llevar la contabilidad ni preparar registros de inf. financiera.
 - Diseñar o implementar un sistema de inf. financiera.
 - Tercerizar los servicios de auditoría, entre otras incompatibilidades.
 - Obliga a una auditoría integrada: amplía la exigencia documental y de evidencia. Su finalidad es mejorar la calidad y confiabilidad de la información financiera.

COSO (Committee of Sponsoring Organizations of the Treadway Commission)

Es una norma de control interno, para garantizar razonablemente que los objetivos del negocio serán alcanzados y que eventos no deseables serán prevenidos, detectados y corregidos.

Es una iniciativa de 5 organizaciones del sector privado:

1. Asociación de Contabilidad Americana.
2. Instituto Americano de CPAs (Contadores Públicos Certificados).
3. Asociación de Ejecutivos Financieros Internacionales (CFOs y otros ejecutivos).
4. La Asociación de Contadores y Profesionales de Negocios.
5. Institutos de Auditores Internacionales.

El objetivo de esta norma permite:

- Garantizar el logro de los objetivos.
- Que los eventos no deseables serán prevenidos o detectados o corregidos (gestionados).

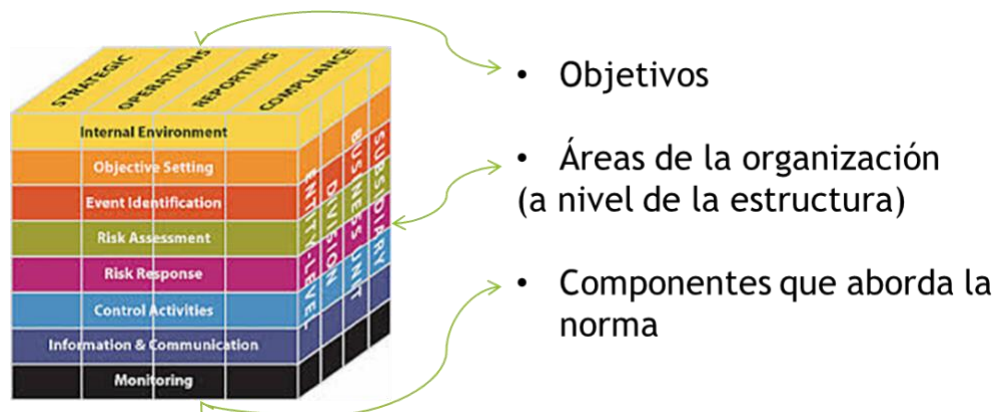


Figura 1: Norma COSO. Fuente: elaboración propia.

Para la norma COSO, el “Control” son las políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para garantizar razonablemente que los objetivos del negocio serán alcanzados y que eventos no deseables serán prevenidos o detectados y corregidos. Los objetivos de control de TI es una definición del resultado o propósito que se desea alcanzar implementando procedimientos de control en una actividad de TI particular.

COSO (Norma de Control Interno)	
Grandes aspectos	• Brinda un esquema general de control interno. • Define las áreas temáticas a analizar (componentes).

	• Criterios para evaluar los sistemas de control interno. • Guía para elaborar informes públicos de CI.
Aspectos a detallar	• El control interno pasa a ser un “Proceso Administrado” de la Dirección o Gerencia para lograr objetivos. • El control interno se ve afectado por la gente de la organización, no sólo por políticas y manuales.
Objetivos primarios	• Asegurar la efectividad y eficiencia de las organizaciones. • Contar con informes financieros exactos. • Cumplir con las leyes y normativa vigente.

HIPAA (Health Insurance Portability and Accountability Act) - USA

Es una Ley de 1996 de portabilidad y responsabilidad del seguro médico.

Establece reglas de Privacidad para la información de los pacientes, reglas de Seguridad para la información de salud, reglas para la notificación ante fugas de información y reglas de simplificación administrativa.

Normas relacionas con Gobierno Corporativo de TI

COBIT (Control Objectives for Information and Related Technology) de ISACA

Es un marco de Negocio para el gobierno y la gestión de las Tecnologías de la empresa.

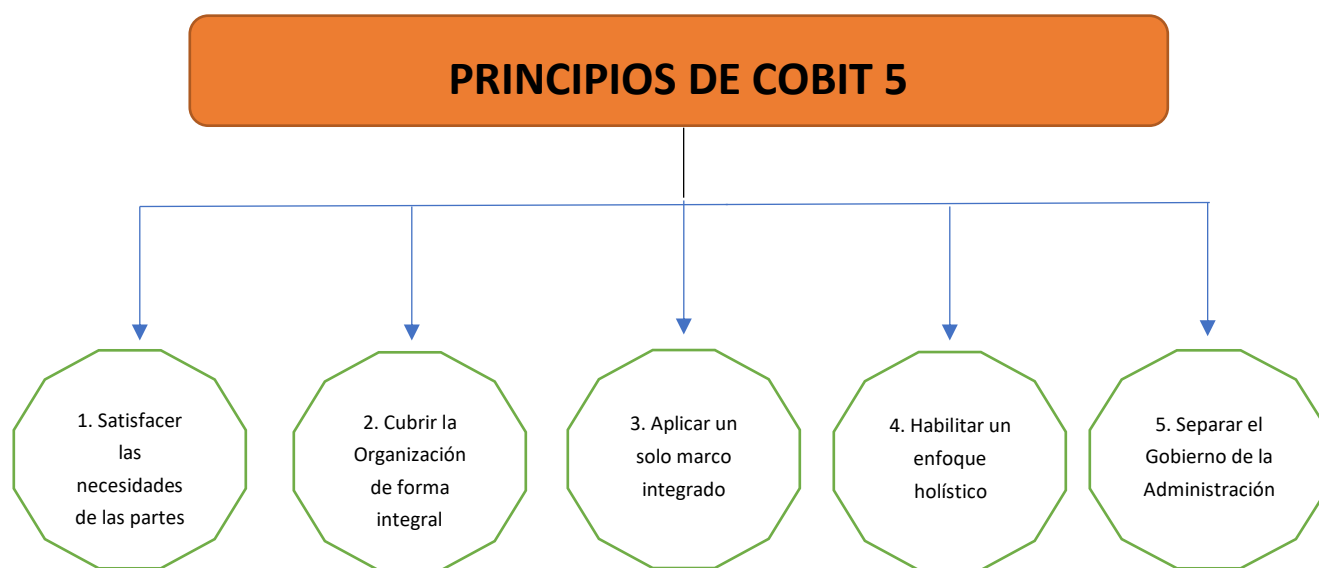
La misión de COBIT es investigar, desarrollar, publicar y promover un conjunto de objetivos de control, mejores prácticas, guías y estándares para el gobierno de TI generalmente aceptados, actualizados periódicamente con el consenso de expertos y para el uso cotidiano por parte de auditores y gerentes de negocio.

Desarrollado y mantenido por el ITGI (*Information Technology Governance Institute*), instituto de investigación independiente y sin fines de lucro. Se encuentra basado en Objetivos de Control de ITGI, alineado con los estándares y regulaciones de jure y de facto. Y basado en la revisión crítica de actividades y procesos.

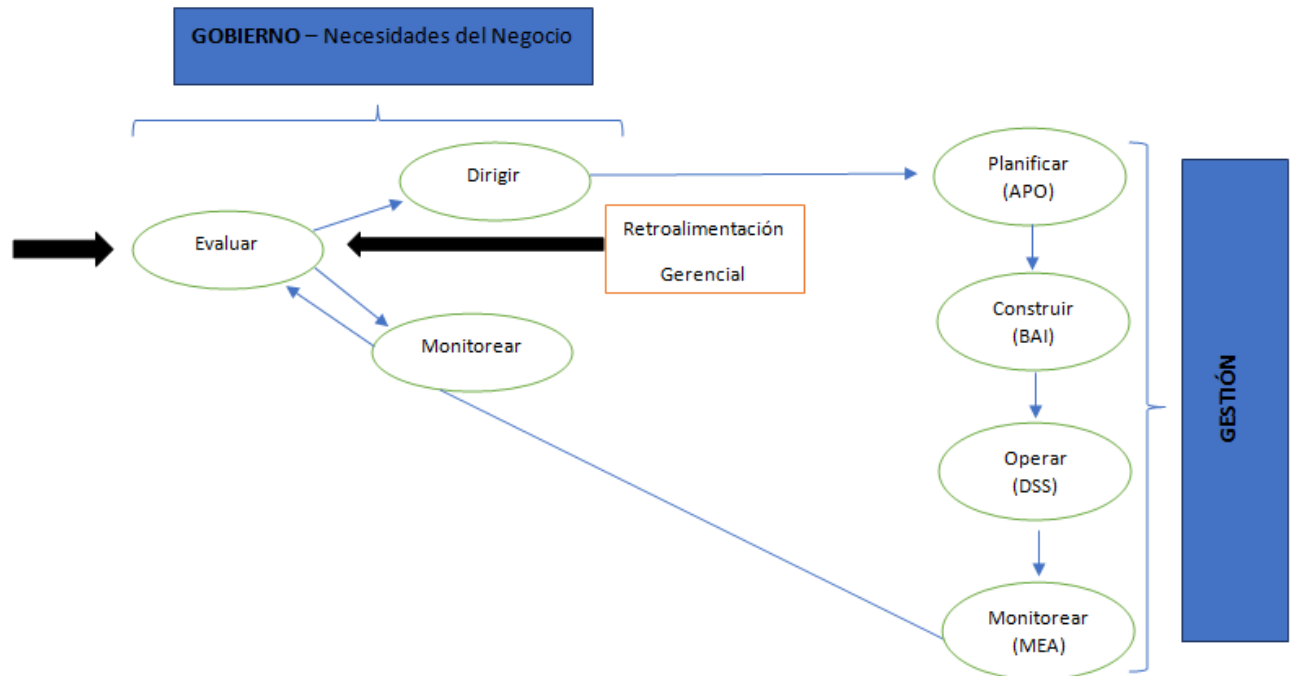
COSO (*Committee of Sponsoring Organisations of the Treadway Commission*) y marcos de referencia similares, está generalmente aceptado como el marco de referencia de control

interno para empresas. COBIT es el marco de referencia de control interno generalmente aceptado para TI.

COBIT reúne a los cinco principios que permiten a la empresa de construir una gobernabilidad efectiva y un marco de gestión basado en un conjunto holístico de siete facilitadores que optimiza la información y la inversión en tecnología y el uso para el beneficio de las partes interesadas.



El modelo divide los procesos de Gobierno de aquellos que son de Gestión en 5 dominios, como figura a continuación:



- 1) Dominio de Gobierno (EDC): se definen las prácticas para:
 - a) Evaluar
 - b) Dirigir
 - c) Controlar
- 2) Dominios de Gestión (PBRM) son 4 dominios alineados con:
 - a) Planificar: APO (Alinear, Planificar y Organizar).
 - b) Construir: BAI (Construir, Adquirir e Implementar).
 - c) Operar: DSS (Entrega, Servicio y Soporte).
 - d) Monitorear (MEA: Monitor, Evaluar y Valorar).

COBIT proporciona un modelo de procesos genérico para funciones de TI, constituyéndose en referencia común entendible para gerentes operativos de TI y del negocio. El modelo de procesos COBIT relaciona por cada proceso los objetivos de control que aseguran su adecuada gestión, las actividades que lo componen, los recursos que las soportan, las métricas de monitoreo que facilitan su alineación con el negocio, prácticas de control recomendadas y modelos de madurez para la evaluación de la capacidad de procesos.

El modelo de madurez permite identificar y demostrar a la Dirección las brechas en la capacidad. De este modo, es posible plantear mejoras para llevar estos procesos hacia el nivel deseado de madurez.

Referencias

ISO/IEC 38000: 2008:

- Guía de Iniciación a Actividad Profesional Buen Gobierno de las Tecnologías de la Información según la norma ISO/IEC 38500 – Colegio Oficial de Ingenieros en Telecomunicaciones marzo 2013
- <https://www.iso.org/home.html>

Ley SOX:

- <http://interamerican-usa.com/articulos/Leyes/Ley-Sar-Oxley.htm>

COBIT:

- COBIT 5 ISACA® Framework - © 2012 ISACA. All rights reserved. For usage guidelines, see www.isaca.org/COBITuse. Procesos Catalizadores.
- <https://www.isaca.org/>